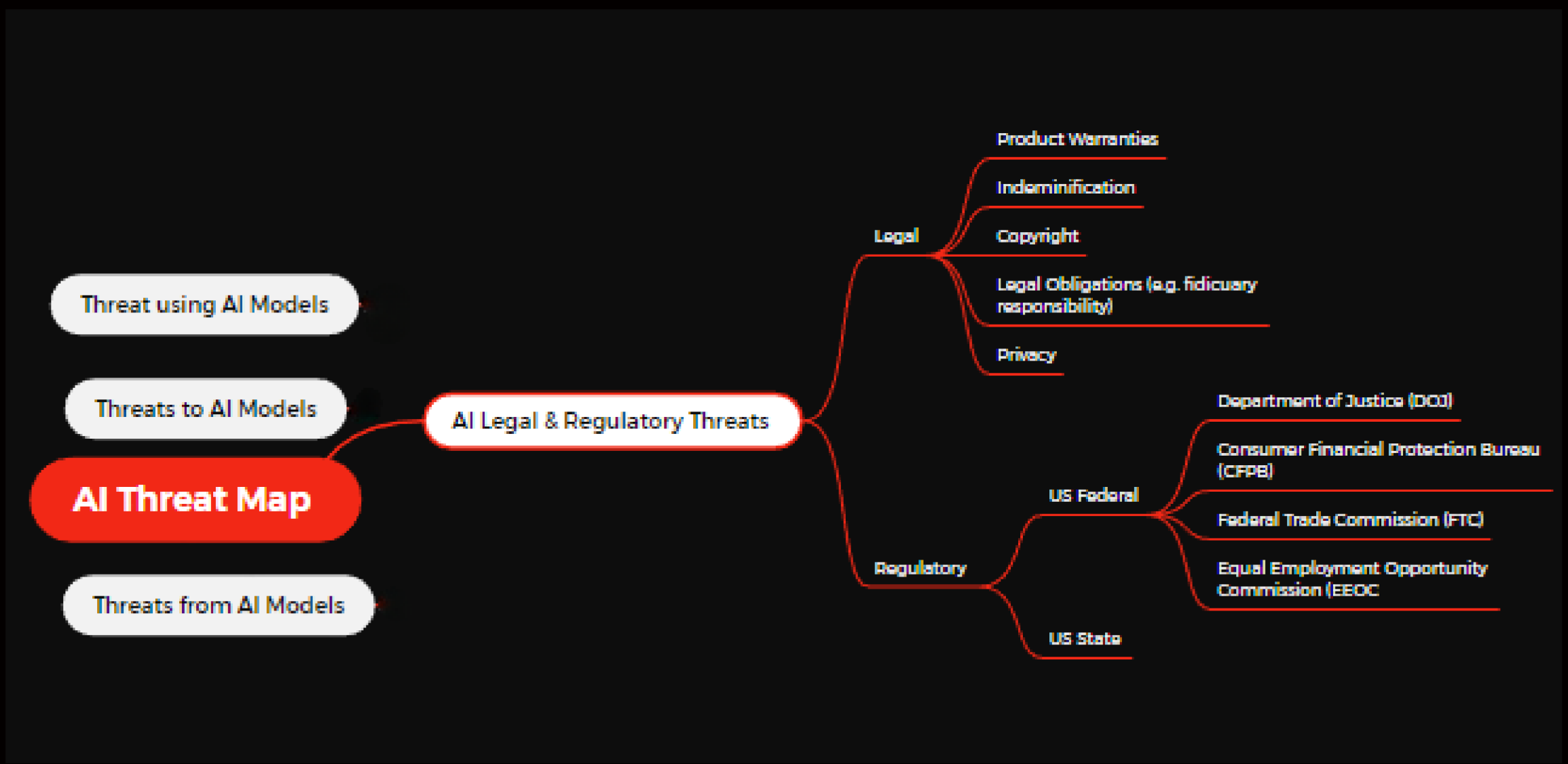
Sandy Dunn,CISO

Using NIST AI Risk Management Framework

To Minimize AI legal & Regulatory Threat

Govern → **Map** → **Measure** → **Manage**



https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

Govern

Determine organization AI RACI

Create AI Policy supported by established policy (standard of good conduct, data protection, software use)

Restrict or prohibit use of generative AI tools for employees / contractors where enforceable rights may be an issue or where there are IP infringement concerns

Update data protection policy to emphasize not to input protected or confidential data into nonbusiness managed AI tools.

Tag AI / LLM in asset management for inventory

Document and assign AI risk, risk assessments, and governance responsibility within the organization.

Map

Publish an acceptable use matrix for various generative AI tools for employees use to

Establish purposes of each tool, acceptable use, and includes guidance for the tools' terms of service

Measure

Test sets, metrics, and details about the tools used during test, evaluation, validation, and verification (TEVV)

Rating system for Bias

https://arxiv.org/pdf/1808.00089.pdf

Google What-if tool

https://pair-code.github.io/what-if-tool/

FairML: Auditing Black-Box Predictive Models

https://github.com/adebayoj/fairml

Microsoft Counterfit

https://github.com/Azure/counterfit

Manage

Treatment of documented AI risks prioritized

AI risks & benefits from third-party resources are regularly monitored, and risk controls are applied and documented.

Contact for more information on AI Threat Mitigation
info@quarkiq.com

https://www.linkedin.com/in/sandydunnciso/